

Name: Neel Pankaj Soni

Student ID: 1259189

Privacy Management Tools

To operationalize the governance framework, the following two detailed checklists have been created. These are practical tools for teams to ensure compliance and assess control effectiveness throughout the development and maintenance of the LetsPayMate application.

Checklist 1: Data Collection & Processing Compliance Checklist

This checklist must be completed for every new feature, service, or third-party integration before launch to ensure compliance with data minimization, lawfulness, and transparency principles.

Part A: Lawfulness & Transparency

- **Purpose Specification:** Is the purpose for data collection specific, explicit, and documented?
- **Lawful Basis Identified:** Is the lawful basis for processing (e.g., Consent, Contractual Necessity, Legitimate Interest) clearly identified and documented for each data type and purpose?
- **Privacy Notice Updated:** Has the privacy notice/policy been updated to accurately reflect the new collection and processing activities? (GDPR Art. 13/14)
- **Consent Mechanism (if applicable):** If relying on consent, is the consent mechanism:
 - **Freely Given?** (Not bundled with Terms of Service)
 - **Specific?** (Granular for different purposes)
 - **Informed?** (User knows what they are agreeing to)
 - **Unambiguous?** (Requires a clear affirmative action)
 - **Easily Withdrawable?** (As easy as it was to give)

Part B: Data Minimization & Scope

- **Necessity Assessment:** For each data point collected, can you justify why it is strictly necessary to achieve the specified purpose?
- **Data Minimization in Design:** Is the system designed to collect only the minimum data required? (e.g., not collecting a birthdate when only age verification is needed)

- **Sensitive Data Justification:** If collecting "Special Category" or high-sensitivity data (e.g., biometrics for KYC), is there a compelling justification and an additional lawful basis under GDPR Art. 9?

Part C: Third-Party & User Rights

- **Third-Party Due Diligence:** If data is shared with a third-party (SDK/API), has a Data Processing Addendum (DPA) been signed, and have their security/privacy practices been vetted?
- **User Rights Fulfillment:** Can the system technically and procedurally fulfill user rights requests (Access, Rectification, Erasure, Portability) for this new data within the GDPR-mandated one-month timeline?

Completion Sign-off:

- **Product Owner:** _____ Date: _____
- **Data Protection Officer (DPO):** _____ Date: _____

Checklist 2: Security & Privacy Controls Effectiveness Checklist

This checklist is for periodic reviews (e.g., quarterly or after significant changes) to audit the operational effectiveness of key privacy and security controls.

Part A: Data Security & Access Controls

- **Encryption in Transit:** Is all data transmitted using strong, up-to-date protocols (TLS 1.2+)? Verified via external penetration tests.
- **Encryption at Rest:** Are all databases and file stores containing personal data encrypted using strong standards (e.g., AES-256)? Are encryption keys managed securely in a dedicated service?
- **Access Control Review:** Has a quarterly review of access rights been conducted to ensure employees and systems only have access to the data necessary for their role (Principle of Least Privilege)?
- **Authentication & Session Management:** Are multi-factor authentication (MFA) and secure, timed session logouts enforced for all administrative access to backend systems?

Part B: Data Governance & Retention

- **Data Retention Compliance:** Is there evidence that automated data deletion jobs are running successfully according to the defined retention schedule (e.g., purging raw KYC data after 30 days)?

- **Anonymization/Pseudonymization:** Where possible, is data being anonymized or pseudonymized for internal analytics to reduce privacy risk?
- **Incident Response Readiness:** Has the Incident Response Plan been tested via a tabletop exercise in the last 12 months? Are all relevant team members familiar with their roles in a breach scenario?

Part C: Ongoing Privacy Improvement

- **Privacy Training:** Have all relevant employees (especially engineering and customer support) completed annual privacy and security training?
- **Vendor Management:** Have the security and privacy posture of key third-party vendors (e.g., KYC provider, payment processor) been re-assessed in the last year?
- **DPIA Review:** Have existing Data Protection Impact Assessments (DPIAs) for high-risk processing been reviewed and updated in the last year or after any significant system change?

Auditor Sign-off:

- **Internal Auditor / Security Lead:** _____ **Date:** _____